

Web Application Security Testing using DVWA and Burp Suite

❖ Objective

To identify and exploit common web application vulnerabilities in a controlled environment using DVWA (Damn Vulnerable Web Application) and Burp Suite.

❖ Tools Used

- Kali Linux
- DVWA
- Burp Suite Community Edition
- Firefox Browser
- Apache2
- MariaDB

❖ Lab Setup

Application: DVWA

Web Server: Apache2

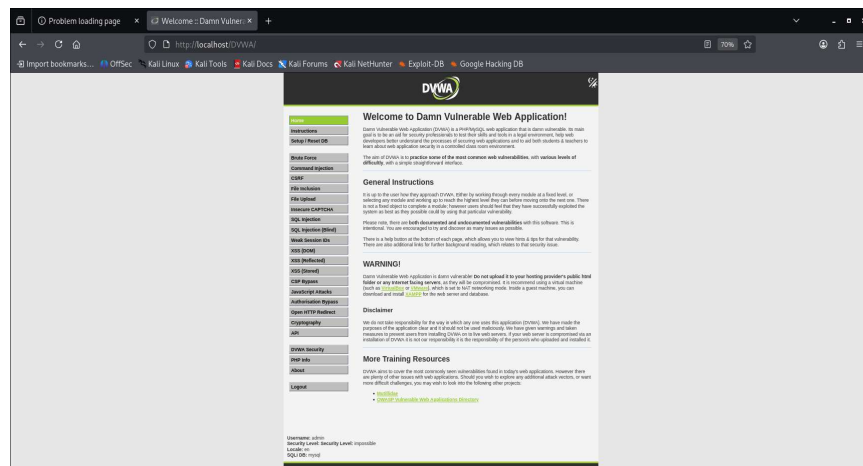
Database: MariaDB

Testing Tool: Burp Suite Community Edition

❖ Methodology

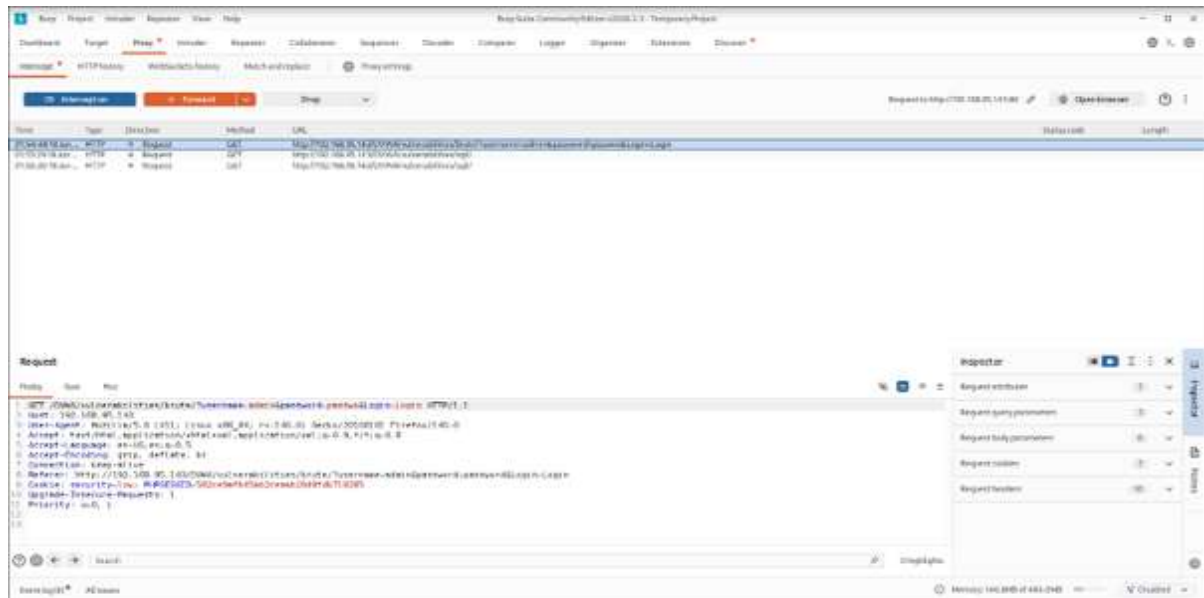
1. Application Enumeration

Configured DVWA and verified application accessibility through a web browser.



2. Traffic Interception

Configured Burp Suite proxy to intercept and inspect HTTP requests and responses between the browser and the application.



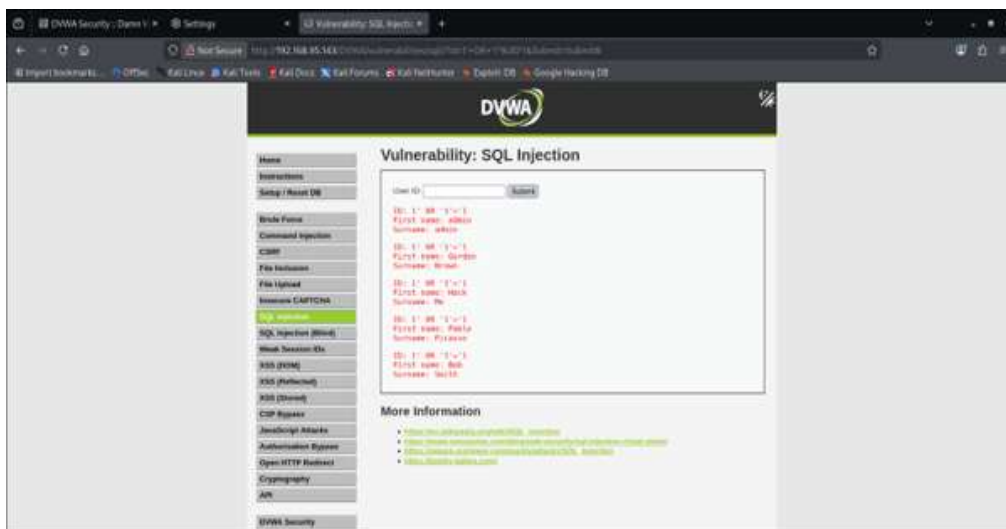
3. SQL Injection Testing

Module Tested:
SQL Injection

Payload:
' OR '1'='1

Result:

The application returned multiple user records, demonstrating improper input validation and successful SQL Injection.



4. Cross-Site Scripting (XSS)

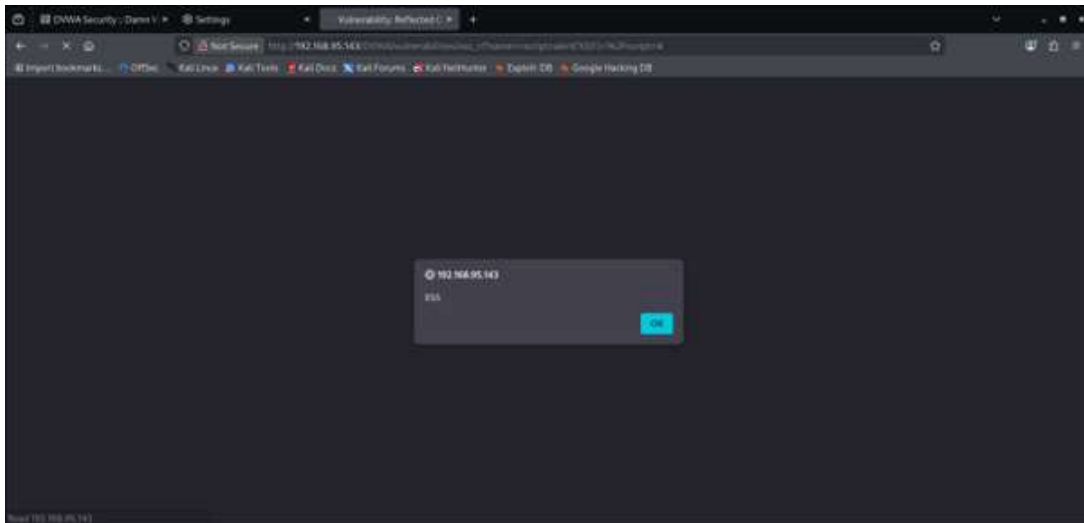
Module Tested:

Reflected XSS

Payload: `<script>alert('XSS')</script>`

Result:

The browser executed injected JavaScript code, confirming the presence of an XSS vulnerability.



5. Command Injection

Module Tested:

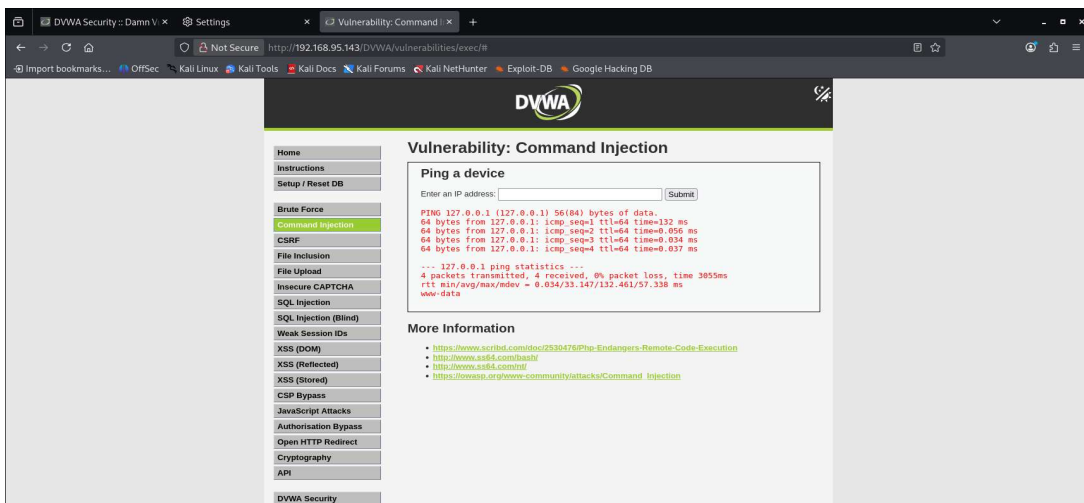
Command Injection

Payload:

`127.0.0.1; whoami`

Result:

Additional operating system commands were executed on the server, demonstrating command injection vulnerability.

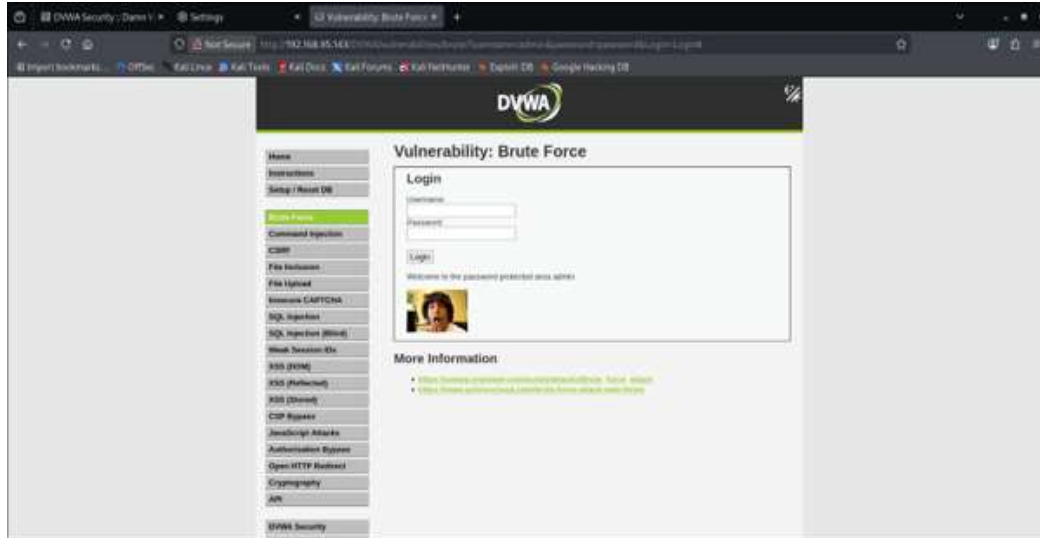


6. Authentication Testing

Module Tested:

Brute Force Authentication

Observed login request parameters using Burp Suite and analyzed authentication mechanisms.



❖ Findings

The application contained several critical vulnerabilities:

- SQL Injection
- Reflected Cross-Site Scripting (XSS)
- Command Injection
- Weak Authentication Controls

These vulnerabilities could allow attackers to gain unauthorized access, extract sensitive data, or execute arbitrary commands.

Finding ID	Vulnerability	OWASP Category	CVSS v3.1 Score	Severity	Impact
DVWA-01	SQL Injection	A03:2021 Injection	9.8	Critical	Database compromise and authentication bypass
DVWA-02	Command Injection	A03:2021 Injection	9.8	Critical	Remote command execution on server
DVWA-03	Reflected XSS	A03:2021 Injection	6.1	Medium	Client-side script execution and session theft
DVWA-04	Weak Authentication (Brute Force)	A07:2021 Identification & Authentication Failures	7.5	High	Unauthorized account access

❖ **Recommendations**

- Implement server-side input validation.
- Use parameterized SQL queries.
- Apply output encoding to prevent XSS.
- Restrict system command execution.
- Enforce strong authentication mechanisms.
- Conduct periodic security testing.

❖ **Conclusion**

This project demonstrated practical web application penetration testing techniques using DVWA and Burp Suite. Multiple vulnerabilities were identified and successfully exploited in a controlled environment, providing hands-on experience with common web security weaknesses and remediation strategies.